Why do cookies need a client-side property?

Why do user credentials require a client-side component while all other CORS features don't? The answer is, again, safety. Because user credentials are often used to perform sensitive actions (such as identify a user or update a user's personal data), the CORS spec needs to be absolutely certain that credentials should be included in the request. Having the client opt-in along with the server adds another layer of caution when adding sensitive data such as user credentials.

5.1.4 How withCredentials and Access-Control-Allow-Credentials interact

Supporting user credentials requires that the `withCredentials` property work in tandem with the Access-Control-Allow-Credentials header. Each can either be set to `true` or `false` (or the property can't be set at all, which is the same as setting it to `false`). This leads to four combinations of properties. This can get confusing, and it may not be clear what a particular combination means. Table 5.1 summarizes how the values interact.

Table 5.1 Behavior for various values of the `withCredentials` property and Access-Control-Allow-Credentials header

withCredentials	Access-Control-Allow-Credentials	Status	Caveats
`false`	`false`	Allowed	Cookies *aren't* included in the request
`true`	`true`	Allowed	Cookies *are* included in the request
`false`	`true`	Allowed	Cookies *aren't* included in the request
`true`	`false`	Rejected	Invalid because cookies are sent on the request, but the server doesn't allow them

As you can see, only one combination leads to a rejection. But the other combinations lead to subtly different behavior, as indicated by the Caveats column in the table.

Let's examine these four combinations in more detail in the following tables.

Table 5.2 Client code and server HTTP response when `withCredentials` and Access-Control-Allow-Credentials aren't set

Client code	Server HTTP response

`var xhr = new XMLHttpRequest();`
`xhr.open('GET',`
`  'http://127.0.0.1:9999/api/posts');`
`xhr.send();`
	`HTTP/1.1 200 OK`
	`Access-Control-Allow-Origin:`
	`  http://localhost:1111`

If `withCredentials` and Access-Control-Allow-Credentials aren't set, cookies aren't included on the request. You've seen how CORS requests behave when these properties